第 47 卷 增刊
2017 年 11 月

东南大学学报(自然科学版)
JOURNAL OF SOUTHEAST UNIVERSITY (Natural Science Edition)

Vol. 47 Sup
Nov. 2017

doi:10.3969/j.issn.1001-0505.2017.S1.008

同形异义的国际化域名检测与测量

刘 莹 刘保君

(清华大学网络科学与网络空间研究院,北京 100084)

摘要: 国际化域名为同形异义钓鱼攻击提供了一种便捷的途径.为进一步理解国际化域名被攻击者滥用的现状,设计了一种基于被动 DNS 数据集和图像相似度算法的轻量级测量系统,以研究目前国际化域名用于同形异义钓鱼攻击的现状.在检测阶段,系统从 360 被动 DNS 数据集中提取活跃国际化域名列表,采用基于指纹信息的图像相似度算法,检测国际化域名是否与知名域名形近.在测量阶段,分析同形异义的国际化域名注册信息,DNS 请求规模,网站用途.结果显示,同形异义国际化域名被抢注的现象严重,已 172 个国际化域名被攻击者滥用,包括钓鱼攻击,域名恶意停放服务等.国际化域名的品牌保护已经成为亟待解决的问题.

关键词: 国际化域名;域名滥用;同形异义攻击;被动 DNS

中图分类号: TP393.0 **文献标志码:** A **文章编号:** 1001-0505(2017)S1-0039-05

Detecting and measuring IDN homograph attack

Liu Ying Liu Baojun

(Institute for Network Sciences and Cyberspace, Tsinghua University, Beijing 100084, China)

Abstract: Internationalized domain names (IDNs) provid a convenient way for homograph phishing attack. To better understand the abusing of IDNs by an attacker, a light-weight detection system based on passive DNS data and graph similarity fingerprint algorithm is proposed to identify IDN homograph domains. At the detection stage, active IDNs are extracted from 360 passive DNS data, and the similarity with the famous domain name is analyzed by a graph similarity algorithm based on fingerprint information. At the measurement stage, the domain names with the register information, DNS query number and content types of web sites are analyzed. The experimental results show that, IDN cybersquatting is a serious problem in real world, 172 IDNs have been used toward malicious activities, including phishing and malicious domain parking, etc. There is an urgent need for a better regulation of domain brand protection.

Key words: internationalized domain names (IDNs); domain abuse; homograph attacks; passive DNS

同形异义攻击是钓鱼攻击的一种形式,这种攻击利用多个字符(字符组合)相似的特点诱导受害者产生视觉错觉[1].国际化域名的出现为同形异义攻击提供了一种新型的攻击途径.国际化域名(internationalized domain name, IDN)是指域名中部分字符属于特殊语言(包括:中文、拉丁文、法文等)字符,即通常无法用软件应用显示的字符[2].2017 年 4 月 17 日,有研究者通过注册国际化域名实现了对苹果官方网站的钓鱼攻击,该事件被国内外安全媒体广泛报道[3-4].由于缺乏国际化域名数据集以及高效的检测方法,目前研究者对网络中现有国际化域名用于同形异义攻击的规模以及形式尚不清楚,本文通过测量研究解答了这一问题.

针对国际化域名同形异义攻击设计了轻量级

收稿日期: 2017-09-21. **作者简介:** 刘莹(1973—),女,博士,副研究员,博士生导师,liuying@cernet.edu.cn.
基金项目: 国家自然科学基金资助项目(61772307)、赛尔网络下一代互联网技术创新资助项目(NGII20160403).
引文格式: 刘莹,刘保君.同形异义的国际化域名检测与测量[J].东南大学学报:自然科学版,2017,47(S1):39-43. [doi:10.3969/j.issn.1001-0505.2017.S1.008]

的测量实验,本文首先提取网络中活跃的国际化域名,接着通过高效的算法识别国际化域名是否与知名域名“同形”,然后研究同形异义的国际化域名 DNS 请求规模,域名注册信息与网站用途等. 测量结果表明:1) 共有 172 个知名网站同形异义的国际化域名活跃在网络中,受到影响的知名网站中不仅包括搜索引擎,购物网站等,还包含支付网站以及政府网站;2) 少数同形异义的国际化域名已经开始被攻击者滥用,从事钓鱼攻击及恶意域名停放服务等;3) 大量(28/29)的同形异义国际化域名是属于被攻击者恶意抢注. 测量结果表明,同形异义国际化域名的品牌保护问题已经成为亟待解决的问题.

1 问题背景

1.1 同形异义攻击

在同形异义攻击研究中,研究者更多的关注 Unicode 编码字符与传统的 ASCII 字符对同形异义攻击的影响[5-7]. 例如,文献[8]在研究钓鱼攻击时说明将同形攻击作为一种重要的分类,赛门铁克的安全报告[9]说明这种同形攻击势必会给钓鱼攻击带来便利,从而给在线银行带来了新的威胁.

1.2 国际化域名

国际化域名的设计初衷是为了母语非英语国家的网民更加便利的访问互联网. 经过 Faltstrom 等[10]的推进,国际化域名的实现标准在 2003 年成为 RFC 标准,并在 2010 年,首个国际化域名的顶级域被加入了 DNS 的根文件. 在国际化域名提出不久,已经有学者研究其带来的安全问题,但是一直未发现具体的案例. 直到 2017 年 4 月份,发现了一起真实的通过构造国际化域名实现对苹果官网钓鱼的案例[3-4],该事件被大量安全媒体报导,国际化域名研究重新回到了研究者的视野.

综上所述,国际化域名的出现给攻击者实现同形异义攻击提供了新的思路,也有安全机构指出国际化域名会对域名的品牌保护带来负面影响. 尽管很多研究说明国际化域名形近攻击可能存在,然而,极少发现真实的案例. 即,目前仍然未有全面的测量研究来揭露这种攻击的规模以及相应真实的影响力. 本文通过大规模的测量研究来阐述这一问题.

2 攻击模型

本文关注的攻击模型为,攻击者首先注册与知名域名形近的国际化域名,并通过多种可能的手段诱导受害者访问该域名. 攻击者的国际化域名将通过解码后,使用浏览器默认字体显示在其地址栏中欺骗受害者,从而达到钓鱼攻击的目的.

3 测量方法与数据集

针对同形异义国际化域名的测量研究需要解决两个关键问题:1) 如何获取国际化域名的列表;2) 如何判定一个国际化域名与知名域名是否为同形. 本文分别在 3.1 节与 3.2 节中阐述如何解决这两个问题.

3.1 国际域名列表

国际化域名列表的获取通常有两种做法:(1) 与域名注册商合作,获取完整的国际化域名注册列表;(2) 通过被动 DNS 系统(在网络中捕获 DNS 流量,经过数据处理后,归档留作分析的系统)流量分析[11],获取活跃的国际域名列表. 第(1)种方式获取的国际化域名尽管已经被注册,但是有可能还未被真正的使用,并且这种获取方式对于研究机构而言存在难度. 本文选用第(2)种方式获取国际域名的列表. 360 DNS 派是中国最大的可供公开查询的被动 DNS 数据集,它每天处理超过 2 400 亿条 DNS 查询,并且已经向研究机构公开数据的查询接口.

本文对 2017 年 4 月 1 日 ~ 27 日 27 d 内的 DNS 流量进行分析. 图 1 为 27 d 内每天所观察到的国际化域名数量,以及国际化域名被客户端请求的总次数. 每天活跃在网络中国际化域名数量约为 20 万个,这些域名每天被请求的总量约在 120 万次,但是在 4 月 19 日出现陡增. 通过处理被动 DNS 数据集,本文共计得到了 5,567,798 个国际化域名.

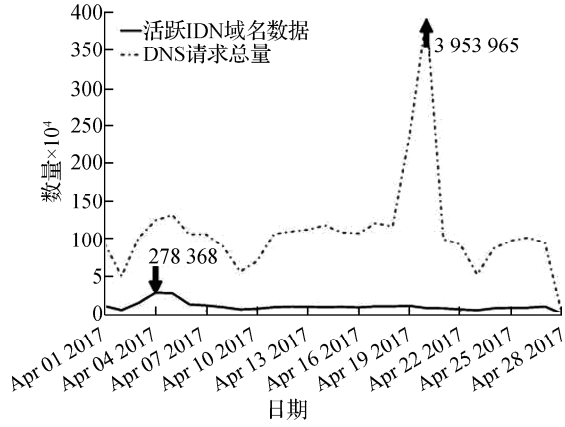

图 1 国际化域名的数量以及 DNS 请求次数

3.2 识别“同形异义”的国际化域名

判断国际化域名是否被攻击者用于同形异义

攻击是一项非常具有挑战的工作. 作者将国际化域名是否同形的问题转换为图像相似度识别问题,并使用基于图像特征方法识别国际化域名解码后的字符是否与知名域名(Alexa 排名前一万)"同形".

首先,作者解释文中所用到的图像特征的提取算法,PHash 算法[12]. PHash 算法与 MD5 和 SHA1 加密散列算法不同,它的作用是为一个图像生成一个独特的指纹,并且这些指纹是可以相互比较的. 算法会首先缩小图像的尺寸并转化为灰度图像,简化图像的色彩,接着使用离散余弦变换(discrete cosine transform, DCT)分解图像的灰色频率,并求取其系数. 最终计算离散余弦变换系数的均值,这个值便是图像的 PHash 数值. PHash 算法实现的效果是,越相似的两个图像,其 PHash 数值也将越接近.

表 1 是程序实现的的详细步骤以及运行结果. 1) 选取 Alexa 排名前一万作为热门域名列表,并将域名通过 Sans Serif 字体编码(与 Chrome 浏览器编码域名的字体保持一致)分别存储为独立的 PNG 图像;2) 然后,本文将所有国际化域名也用这种方式保存为一张 PNG 图像. 在图像特征提取中,使用上述的 PHash 算法,快速地提取每个图像的指纹,也称为 PHash 数值,该算法主要优势是开销低并且计算数值可以相互比较;3) 比较 PHash 数值序列,找出所有 PHash 数值相同的图片,并得到与之对应的知名网站域名以及国际化域名对应关系. 运行时间说明,本文方法耗时主要取决于测量域名的规模,在 500 万量级的域名分析上,该运行时间是在接受范围内的.

表 1　程序各阶段运行耗时

程序运行阶段	步骤	算法耗时 H:M:S
AlexaTop1	PNG 文件生成	00:01:10
万热门域名	PHash 数值生成	00:00:53
556 万	PNG 文件生成	03:24:39
国际化域名	PHash 数值生成	02:37:50
特征比较		00:13:05
共计		06:36:55

4　测量结果

通过上述测量实验,本文共得到 172 个目前活跃在网络中的同形异义的国际化域名. 这些国际化域名共计影响了 93 个知名域名. 我们将对这 172 个国际化域名作进一步的测量研究,分析域名的 DNS 请求规模,注册者信息以及网站业务类型.

4.1　潜在受影响的知名网站分布

我们首先分析了同形异义的国际化域名热衷于模仿哪些域名. 如表 2 所示,同形国际化域名更倾向于模仿知名的公司、支付、搜索引擎及购物网站. 支付网站的钓鱼对用户的威胁最大,会给受害者带来最直接的影响. 具体来说,有 23 个国际化域名模仿苹果公司的官网网站(www. apple. com),在列举的两个案例中,一个是采用替换字母"p"的语言实现模仿,一个是采用了替换"a","p","e"三个字母进行模仿. 对于潜在的受害用户而言,这些字母的替换足以起到混淆欺骗的目的.

表 2　受影响网站案例

网站域名	网站类型	形近域名数量	举例(国际化域名;解码后字符)
apple. com	知名公司	23	xn-ale-0eda. com; apple. com xn-l-7sbq6ba. com; apple. com
alipay. com	支付	15	xn—lipay-3ve. com; alipay. com xn—l-7sbb7dq5i. com; alipay. com
taobao. com	购物	13	xn—taobo-7ve. com; taobao. com xn—tabao-kye. com; taobao. com
google. com	搜索引擎	12	xn—gg-olc8aa58f. com; google. com xn—googl-3we. com; google. com
facebook. com	社交	7	xn—facebok-i5b. com; faceboo′k. com xn—facebok-y2c. com; facebo̊ok. com

接着,对潜在受影响网站的分布进行分析,如表 3 所示,搜索引擎、社交网站、支付网站、门户网站、知名公司等均潜在地受到国际域名同形攻击的影响. 更重要的是,作者发现此类国际域名已经开始对政府网站进行模仿,攻击者的这种行为非常值得研究者关注.

4.2　DNS 请求规模

本文对这些同形异义国际化域名的 DNS 访问量进行了统计,见图 2. 从被动 DNS 数据分析,仅有少量的国际化域名有着大规模的访问,如:xn - - 80ak6aa92e. com 以及 122. xn - - govcn - sja,而大量国际化域名被访问的次数较少. 可能的原因包括:1) 被动 DNS 数据集具有地缘性限制;2) 该国际化域名仍然处于测试阶段,攻击没有真正展开.

本文还对图 2 五个热门的国际化域名访问量进行细致的研究,观察每天的变化情况,见图 3. 图

表 3 潜在受影响知名网站类型分布

数目	网站类型	举例
10	搜索引擎	google. com, baidu. com, so. com
10	购物网站	taobao. com, tmall. com, amazon. cn
8	视频网站	youtube. com, yy. com, iqiyi. com
5	新闻及门户	qq. com, hao. 123. com, sina. com
5	色情	/
4	社交	facebook. com, weibo. cn, wechat. com
3	政府网站	gov. cn, saic. gov. cn, 122. gov. cn
3	支付	alipay. com, paypal. com, citi. com
44	知名公司及其他	github. com, oppo. com, ctrip. com

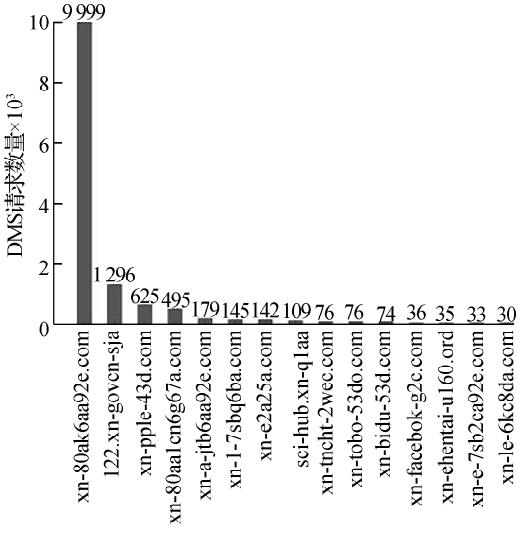

图 2 Top 15 国际化域名的 DNS 访问量

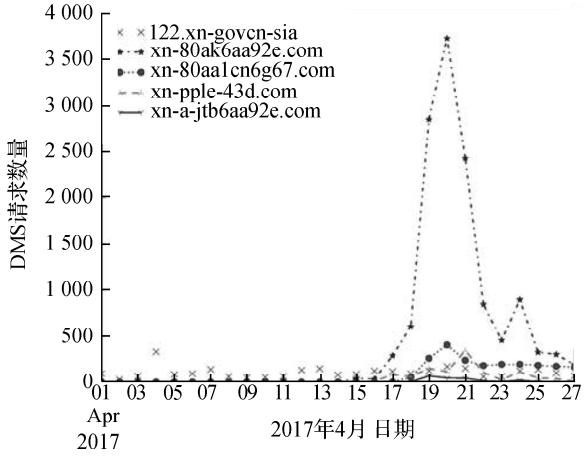

图 3 Top 5 热门国际化域名的每天 DNS 访问趋势

中有如下的发现:1) 域名(122. xn - - govcn - sja)每天均存在数百的访问量,已经在网络中长期存在. 该域名的解码显示形式为 122 · gov. cn(形近的知名域名为 122. gov. cn,公安部互联网交通安全管理平台). 如 4. 1 节所述,此类同形异义的国际化域名攻击已经影响到少数政府网站,这一点值得关注. 2)其他四个国际化域名均存在在 2017 年 4 月 18 日之后访问量攀升的情况,其中以 xn - - 80ak6aa92e. com 最为显著(形近知名域名为 apple. com,苹果公司官网). 本文回溯了关于这个域名的相关事件,最早关于该域名的报道出现在 4 月 18 日的《The Hack News》中[3],并且国内知名媒体[4]于 4 月 19 日翻译了这篇文章,作者认为该域名的访问量是受到了相关报道的激励导致的. 这一事件还导致了其他一些形近国际化域名 DNS 访问量的攀升.

由此看出,同形异义的国际化域名的滥用已经逐渐进入公众的视线,并且有可能造成长时间影响.

4.3 域名注册信息研究

本文还对这些国际化域名的注册信息进行了研究. 上述提到共发现了 172 个同形异义的国际化域名. 借助于安全公司提供的 whois 数据库,共计查询到 29 个国际化域名的注册者信息. 其中仅有一个国际化域名的注册者与其官方域名的注册者一致,这种情况是出于公司的域名品牌保护策略进行及时的域名抢注. 但更多形近异义的国际化域名是被抢注的,如表 4 所示. 并且这种抢注行为在 2014 年后,尤其是 2017 年有爆发的趋势. 这也是本文认为同形的国际化域名攻击是值得警惕的原因.

4.4 网站类型分类

截止目前,共有 24 个域名启用了网站. 网站业务分类主要包含如下类别:钓鱼攻击(1 个),域名停放服务(含恶意行为,10 个),域名品牌保护(4 个),提示信息(4 个),个人博客(1 个)以及其他(4 个),如表 5 所示. 关于“提示信息”主要是研究者用来提醒用户当前访问的网站可能并不是真正的知名网站. 从目前网站的类型中可以看出,确实已经有攻击者开始利用国际化域名从事恶意攻击,包括钓鱼攻击以及域名停放服务等. 作者希望相关的网站能够重视国际化域名的品牌保护,防止受到同形攻击的影响.

5 解决方案

根据目前相关机构的安全策略,我们列出一些缓解措施,包括:1) 停止支持国际化域名,即浏览器不再执行 RFC 的相关规定,但这种方案违背了国际化域名的设计初衷. 2) 支持有限制的国际化域名[13]. 通常而言,用户熟悉比较熟悉语言只是少数几种,浏览器可以记录这种语言偏好设置,并在访问国际化域名对所有字符语言进行判断,禁止访问不在语言偏好中的国际化域名. 3) 改进国际化域名的标准[14]. ICANN 也在防止国际化域名的同形攻击上面做出了努力,即不再接受任何国家或机构申请两个字符的国际化域名顶级域.

上述提到的部分已经实施的解决方案,可以起到显著减小攻击面的作用,对于抵抗同形异义攻击

有着积极作用.

表 4　部分国际化域名注册者信息

知名域名	形近的国际化域名	注册邮箱	注册日期	恶意抢注
google. com	xn—ggle-55da. com	dns-admin@ google. com	2005-02-07	×
	xn—oogle-qmc. com	tetenayimi@ yimicom. com	2014-05-15	✓
	xn—goole-tmc. com	xn—goole-tmc. com@ proxy. dreamhost. com	2009-10-19	✓
apple. com	xn—80ak6aa92e. com	∗. protect@ whoisguard. com	2017-01-19	×
icloud. com	xn—cloud-ssa. com	nexusm@ me. com	2015-02-17	✓
facebook. com	xn—facebok-i0a. com	∗. protect@ whoisguard. com	2016-07-12	×
	xn—facebok-y2c. com	∗. protect@ whoisguard. com	2017-04-12	×
	xn—facebok-i01c. com	∗. @ xn—facebok-i01c. com. whoisproxy. org	2017-02-06	✓
paypal. com	xn—80aa0cbo65f. com	∗ @ contact. gandi. net	2014-10-07	✓

表 5　部分形近异义国际化域名网站类型分类

知名域名	形近的国际化域名	网站类型
facebook. com	xn-facebok-y2c. com	钓鱼攻击
google. com	xn-oogle-qmc. com	恶意域名停放
le. com	xn-e1a12a. com	域名停放
aliexpress. com	xn-alexpress-15a. com	品牌保护
apple. com	xn-80ak6aa92e. com	提示信息
baidu. com	xn-aidu-kcb. com	个人博客

6　结语

本文针对国际化域名同形异义攻击设计了轻量级的测量实验. 研究了目前网络同形异义的国际化域名的规模,注册信息以及网站用途等. 通过实验,作者确认:1)目前已有同形异义的国际化域名已经被攻击者滥用,从事钓鱼攻击及恶意域名停放服务等;2)同形国际化域名的存在大量抢注现象. 国际化域名的品牌保护已经成为亟待解决的问题.

参考文献(References)

[1] Al Helou J, Tilley S. Multilingual web sites: internationalized domain name homograph attacks[C]//12*th IEEE International Symposium on Web Systems Evolution* (*WSE*). Timisoara, Romania, 2010: 89 - 92.

[2] Mac Síthigh D. More than words: the introduction of internationalised domain names and the reform of generic top-level domains at ICANN [J]. *International Journal of Law and Information Technology*, 2010, **18**(3): 274 - 300. DOI:10. 1093/ijlit/eaq007.

[3] Mohit K. Unicode Punycode phishing attack [EB/OL]. (2017-04-17) [2017-05-10]. http://thehackernews. com/2017/04/unicode-Punycode-phishing-attack. html.

[4] Mohit K. A new kind of Punycode phishing attack[EB/OL]. (2017-04-19)[2017-05-10]. http://www. freebuf. com/news/132240. html.

[5] Alvi F, Stevenson M. and Clough P. Plagiarism detection in texts obfuscated with homoglyphs[C]//39*th European Conference on Information Retrieval*. Aberdeen, UK, 2017: 669 - 675.

[6] Liu C, Stamm S. Fighting unicode-obfuscated spam [C]//*Proceedings of the anti-phishing working groups 2nd annual eCrime researchers summit*. Pittsburgh, Pennsylvania, USA, 2017: 45 - 59.

[7] Koegler B. Babel 2. 0: bridging the linguistic digital divide[J]. *Faculty of Information Quarterly*, 2010,2(2).

[8] Lin E, Greenberg S, Trotter E, et al. Does domain highlighting help people identify phishing sites? [C]//*Proceedings of the SIGCHI Conference on Human Factors in Computing Systems*. Vancouver, BC, Canada, 2011: 2075 - 2084.

[9] Canavan J. The evolution of malicious IRC bots [C]// *Virus Bulletin Conference*. Dublin, Ireland, 2005:104 - 114.

[10] Faltstrom P, Hoffman P, Costello A. Internationalizing domain names in applications (IDNA) [R]. UC Berkeley: IETF, 2003.

[11] April. Passive DNS evolution [EB/OL]. (2016-04) [2017-05-10]. https://www. dns-oarc. net/files/workshop-2006/Lorenzen-PassiveDNS. pdf.

[12] Buldas A, Kroonmaa A, Laanoja R. Keyless signatures' infrastructure: how to build global distributed hash-trees [C]//18*th Nordic Conference on Secure IT Systems*. Ilulissat, Greenland, 2013: 313 - 320.

[13] Mozilla contributors. IDN display algorithm [EB/OL]. (2017-04-17) [2017-05-10]. https://wiki. mozilla. org/IDN_Display_Algorithm.

[14] ICANN. Opera's settings file explained: IDNA white list [EB/OL]. (2014-02-19) [2017-05-10]. https:// www. icann. org/resources/pages/string-evaluation-completion-2014-02-19-en.